

From Vulnerability Scan to Exploit Candidate

The workflow

```
OpenVAS scan (or Nessus)
-> extract top CVEs + CVSS
-> check NSE script vulns to corroborate
-> searchsploit / exploit-db for each CVE
-> map to Metasploit if an exploit module exists
-> record: host, port, service, CVE, exploit path, prereqs
-> rank: exploitability (know-how) + asset value
```

Reading scanner output critically

Scanner "High" = numeric CVSS; you must verify actual accessibility and prereqs

A "critical" network vuln on a host with no exploitable service is "informational" for you

Stack context matters: old CVEs without public exploit → lower urgency

Searching for exploits

```
searchsploit openssh 7.2
searchsploit apache 2.4.29
# match services + versions to exploits
# read the exploit header in exploit-db for prereqs
```

Verifying in lab

Before writing "exploitable":

Attempt the exploit against a **replica** lab target

Verify the exact prereq (auth required? DoS only? RCE?)

Document the exact commands (or Metasploit module path)
Note constraints (ASLR/RELRO/stack canary for binary exploits)

Triage as a table

Host	Port	Service	CVE	Exploit	Exploitability	Priority
10.0.0.20	80	Apache 2.4.29	CVE-2018-xxxx	msf module	know-how: Low	P30
10.0.0.30	445	SMBv1	CVE-2017-0143	eternalblue	know-how: High	P0

A vulnerability without a verified path is a hypothesis. A hypothesis becomes a report finding only when you have a documented repro.

[← OS Fingerprinting: Passive, ...](#)

Active Directory Enumeration (...)